

CYBERSNOVA



PROJECT REPORT

Prepared by
NAMRATA RAVINDRA PAWAR.

Field	Details
Full Name	Namrata Ravindra Pawar
Registration Number	CSN-SP-2026-155
Internship Domain	Cyber Security
Duration	1 month
Start Date	1 Sept 2026
End Date	30 Sept 2026
Mode	30 Sept 2026
Assigned Mentor	Internship Coordinator

Level 1=Intermediate

Level

**PROJECT 1— OWASP JUICE SHOP
SECURITY ASSESSMENT**

2. Objective

Identify and successfully exploit at least five different vulnerabilities, demonstrate their impact with evidence, and provide mitigation recommendations.

3. Target

OWASP Juice Shop — local
authorized training instance

4. Tools Used

- Kali Linux
- Mozilla Firefox

Executive Summary.

A security assessment was performed against a locally deployed OWASP Juice Shop instance, an intentionally vulnerable application used for authorized security training.

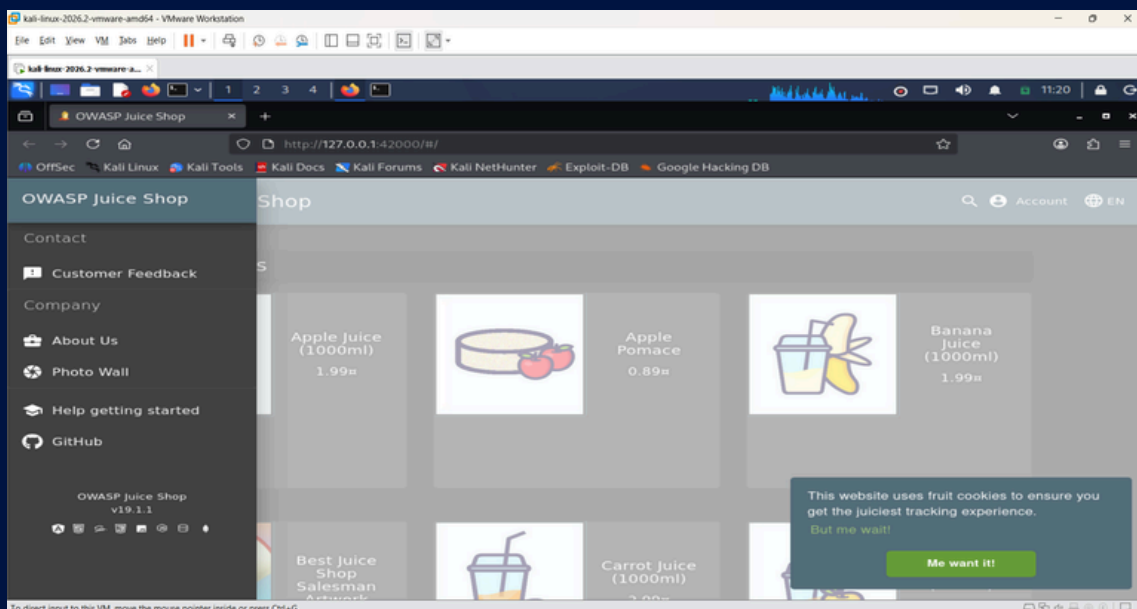
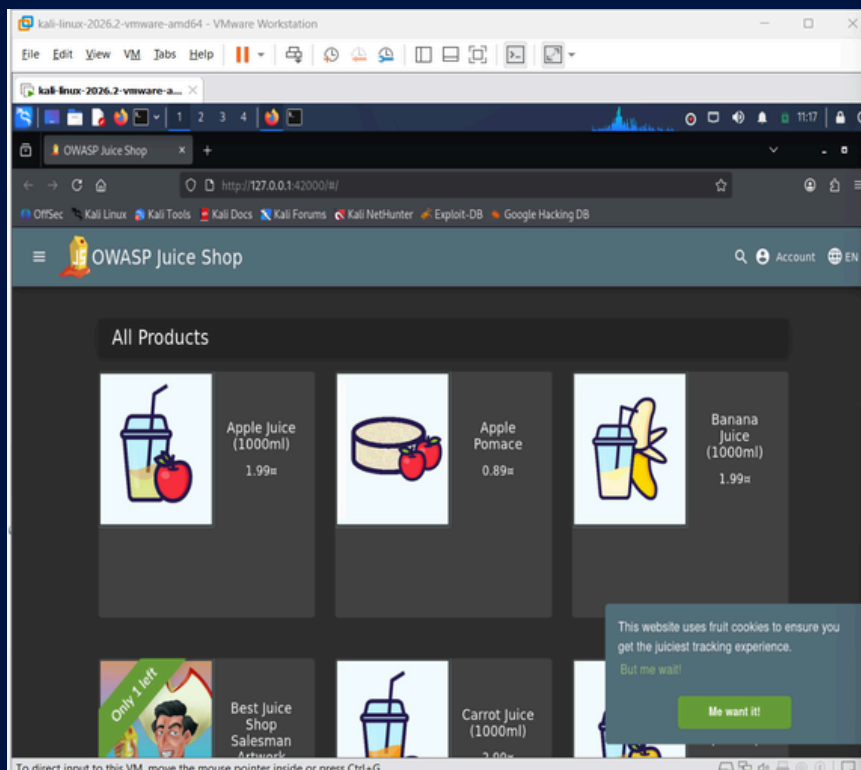
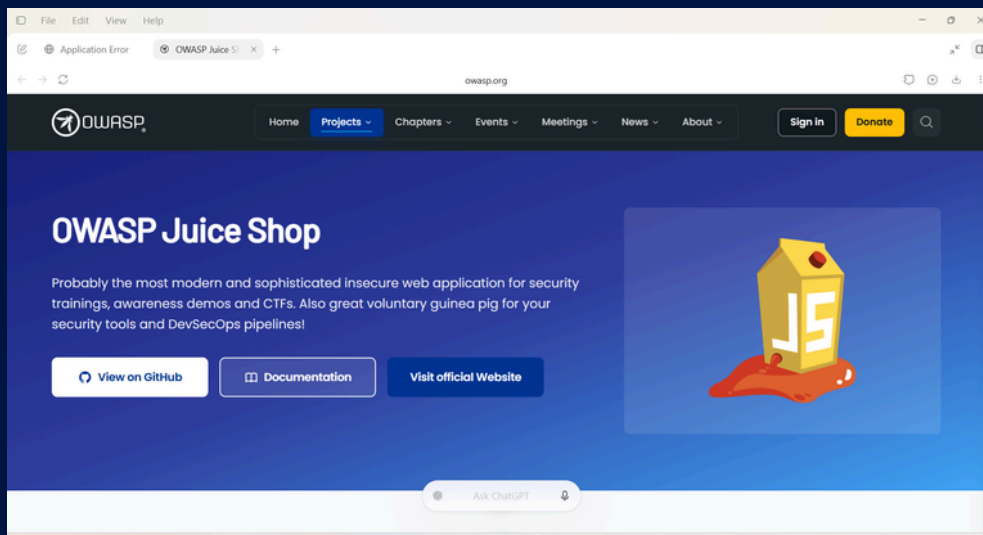
Five different vulnerabilities were successfully identified and demonstrated:

- DOM-based Cross-Site Scripting (DOM XSS)
- Confidential Document / Sensitive Data Exposure
- Login Admin / SQL Injection
- Admin Section / Broken Access Control
- Error Handling / Security Misconfiguration

The testing was conducted only against the locally hosted Juice Shop instance.

Findings Summary.

#	Challenge	Vulnerability Category	Result
1	DOM XSS	Cross-Site Scripting	Successfully exploited
2	Confidential Document	Sensitive Data Exposure	Successfully accessed
3	Login Admin	Injection / SQL Injection	Authentication bypass demonstrated
4	Admin Section	Broken Access Control	Successfully accessed
5	Error Handling	Security Misconfiguration	Detailed error information exposed



DOM-Based Cross-Site Scripting (DOM XSS)

1. Challenge: DOM XSS
2. Category: Cross-Site Scripting
3. Target: Local OWASP Juice Shop v19.1.1

- **Description:** The DOM XSS challenge was successfully exploited by supplying JavaScript through the application's search functionality.
- **Payload Used:** `<iframe src="javascript:alert('xss')">`
- **Result:** The JavaScript payload executed successfully and displayed an xss alert.
- **Impact:** Successful exploitation demonstrates that attacker-controlled input can reach a browser-side execution context. In a vulnerable application, this type of issue can potentially allow malicious scripts to execute in a victim's browser context.

- Evidence:

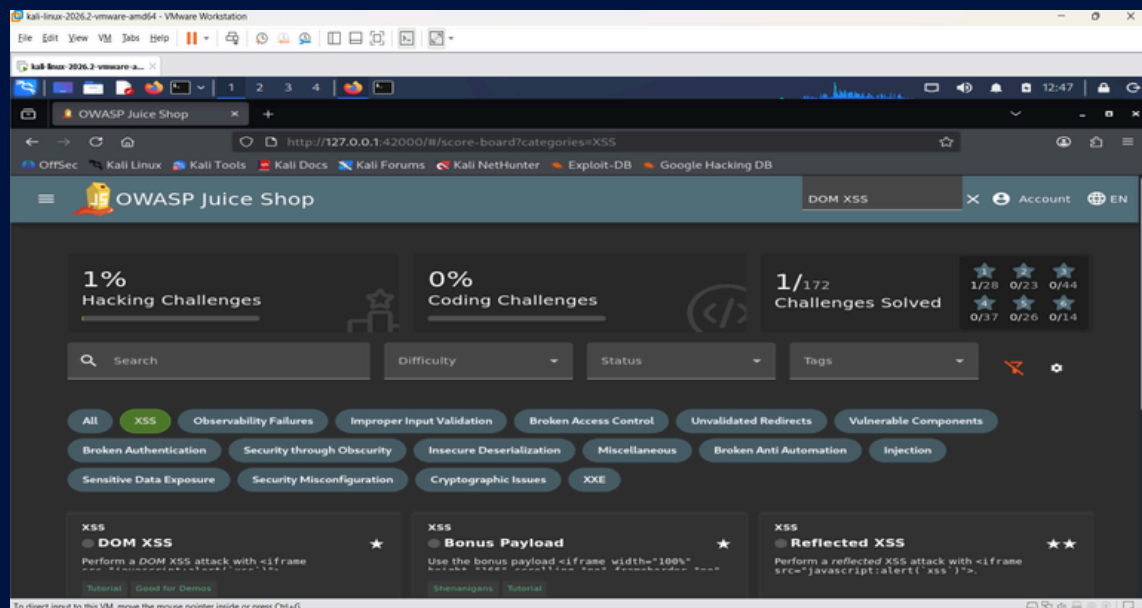


Figure 1. Successful execution of the DOM XSS payload in the OWASP Juice Shop application.

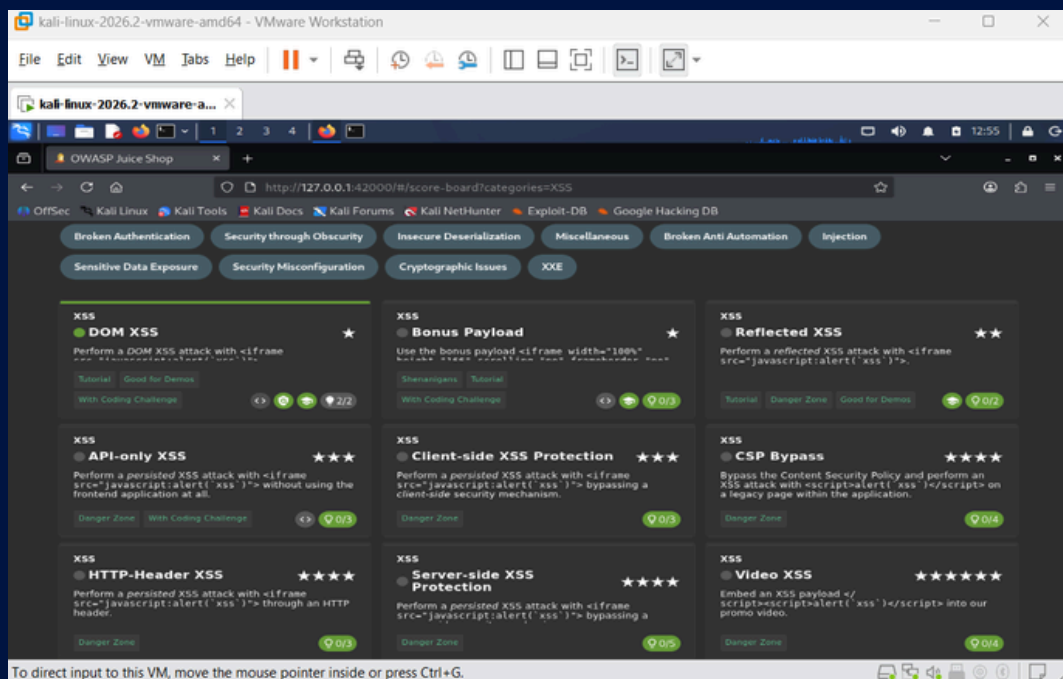


Figure 2. Juice Shop Score Board confirming the DOM XSS challenge was solved.

Confidential Document – Sensitive Data Exposure

- **Description:** Explain that a confidential document was accessed through the Juice Shop application.
- **Result:** The confidential document challenge was successfully completed.
- **Evidence:**

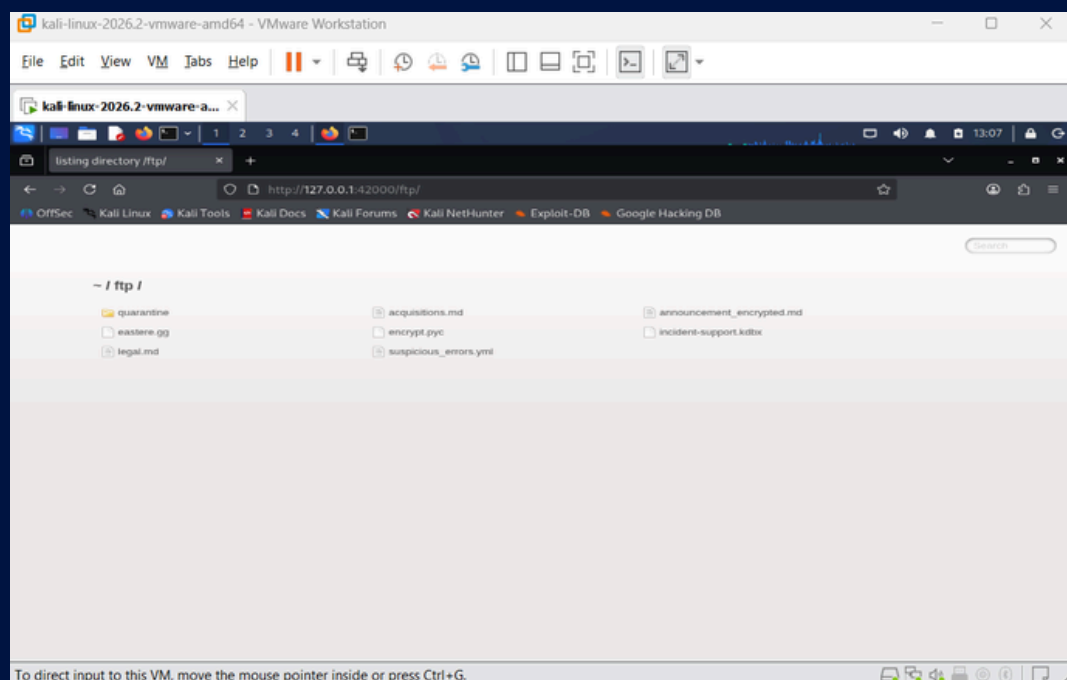


Figure 3. Successful completion of the Confidential Document challenge.

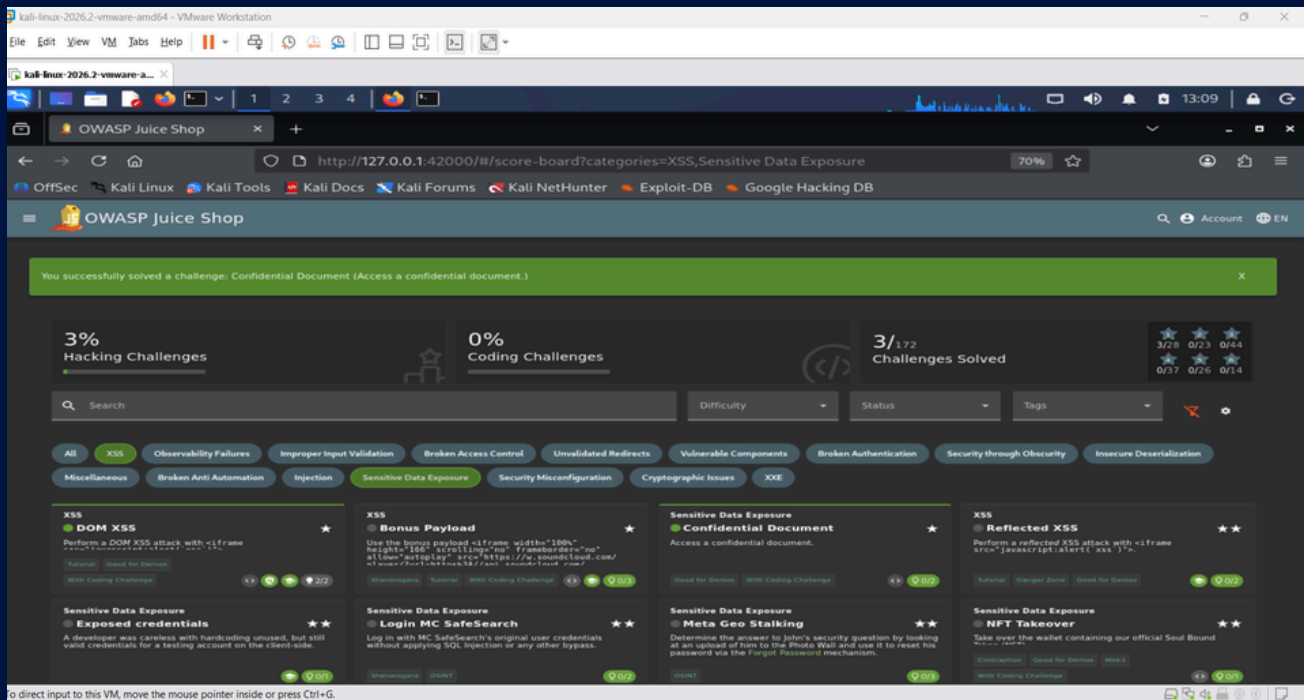


Figure 4. Juice Shop confirmation that the Confidential Document challenge was solved.

Login Admin – SQL Injection

- **Description:**

Explain that the Login Admin challenge tested whether SQL injection could bypass authentication.

- **Payload Used:** ' OR true--

- **Result:**

The authentication mechanism was bypassed and the application authenticated the user as the administrator.

- **Evidence:**

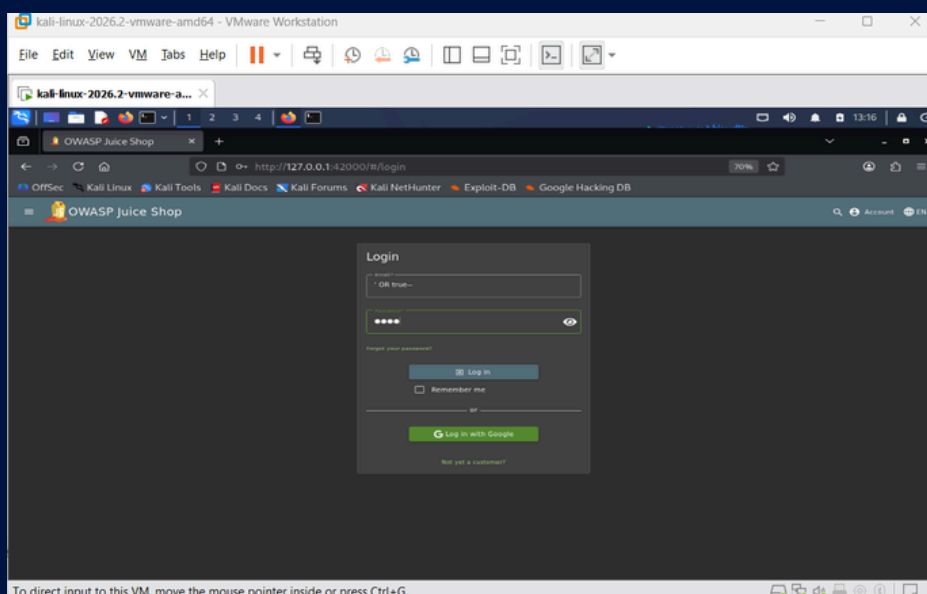


Figure 5. Successful authentication as the administrator after SQL injection.

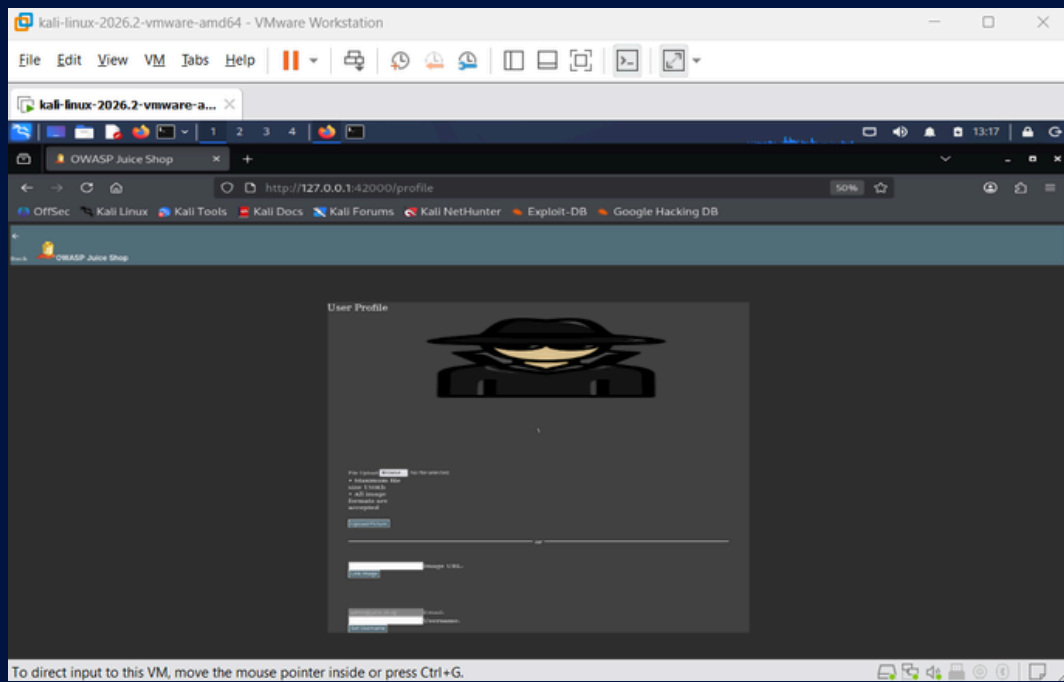
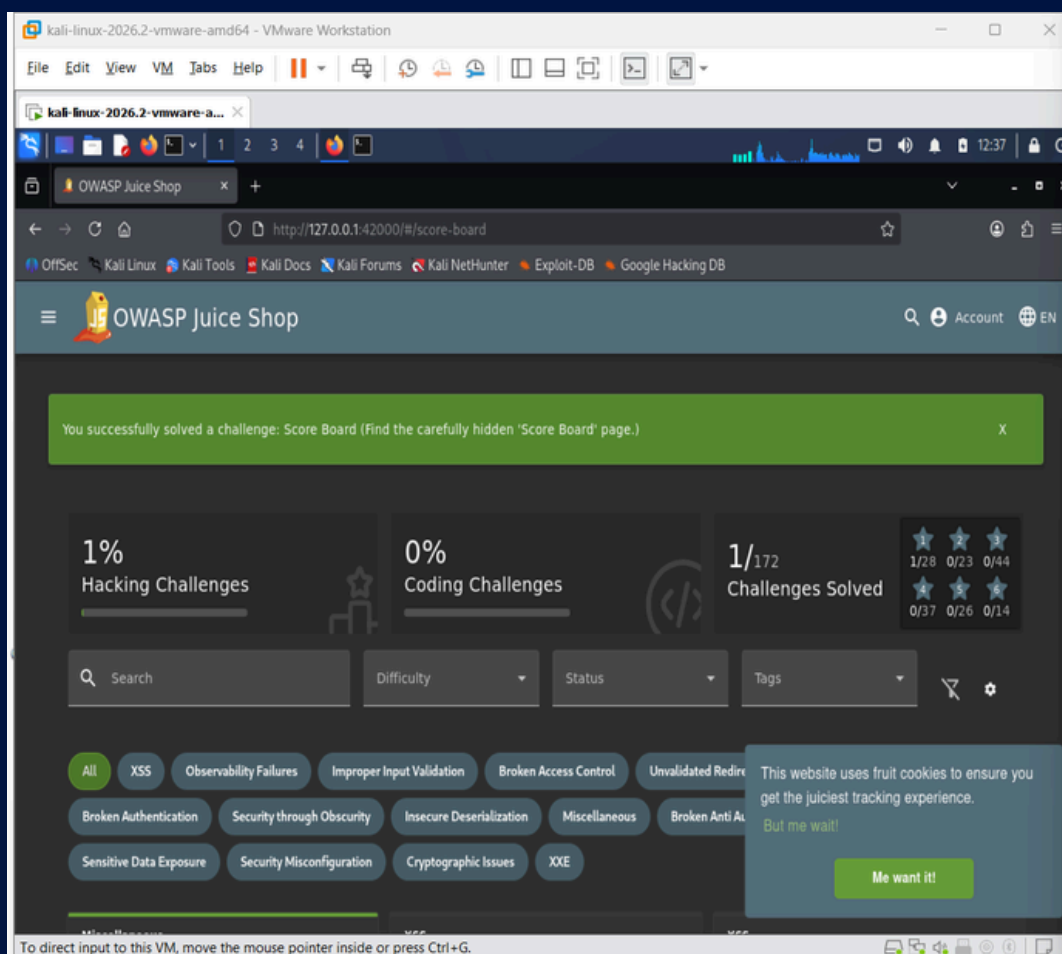


Figure 6. Juice Shop Score Board confirming the Login Admin challenge was solved.



Admin Section — Broken Access Control

- **Description:**

Explain that the administration section was accessed through the Juice Shop application.

- **Result:** The Admin Section challenge was successfully completed.

- **Evidence:**

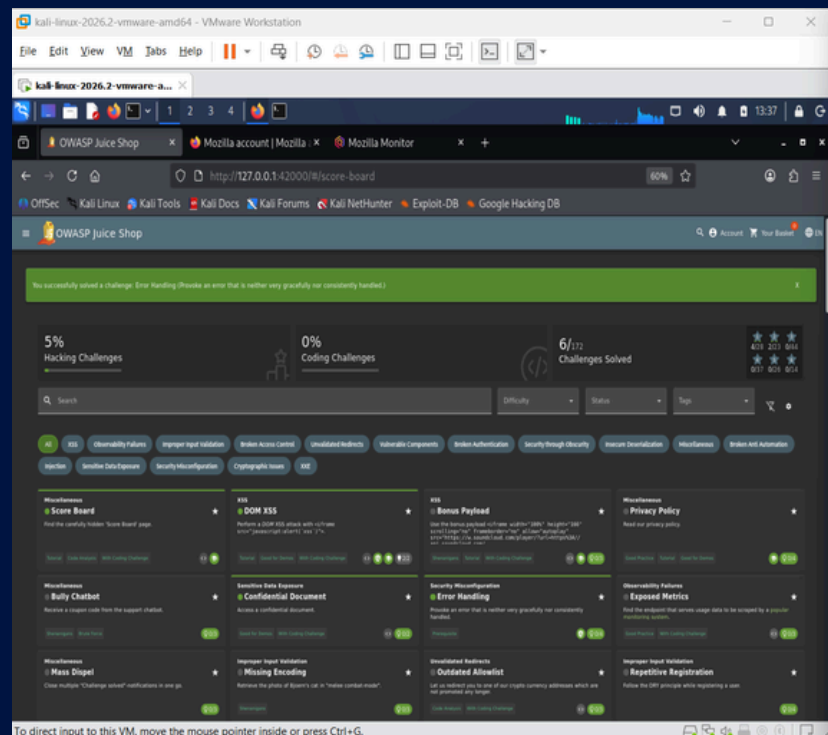


Figure 7. Successful access to the OWASP Juice Shop Administration section and confirmation of the completed challenge.

Error Handling — Security Misconfiguration

- **Description:**

Explain that malformed/unexpected requests caused the application to return detailed error information.

- **Result:**

The application returned an HTTP 500 response containing detailed error information and a server-side stack trace.

- **Evidence:**

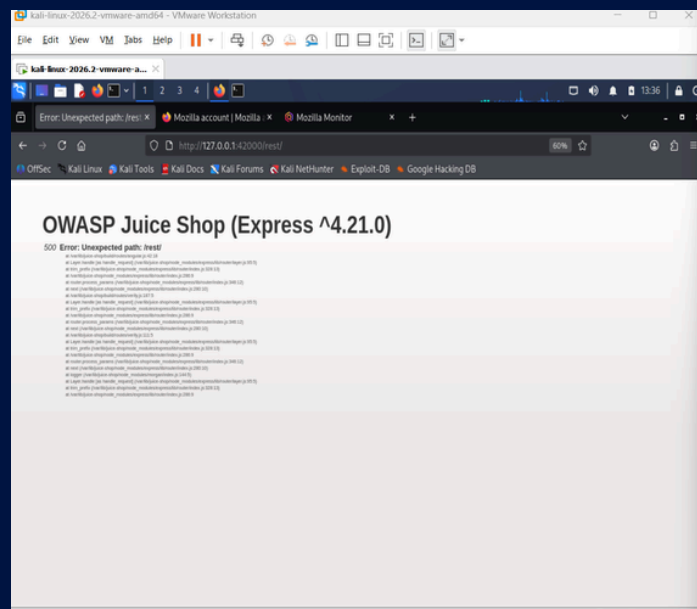


Figure 8. Detailed HTTP 500 error and server-side stack trace exposed by the application.

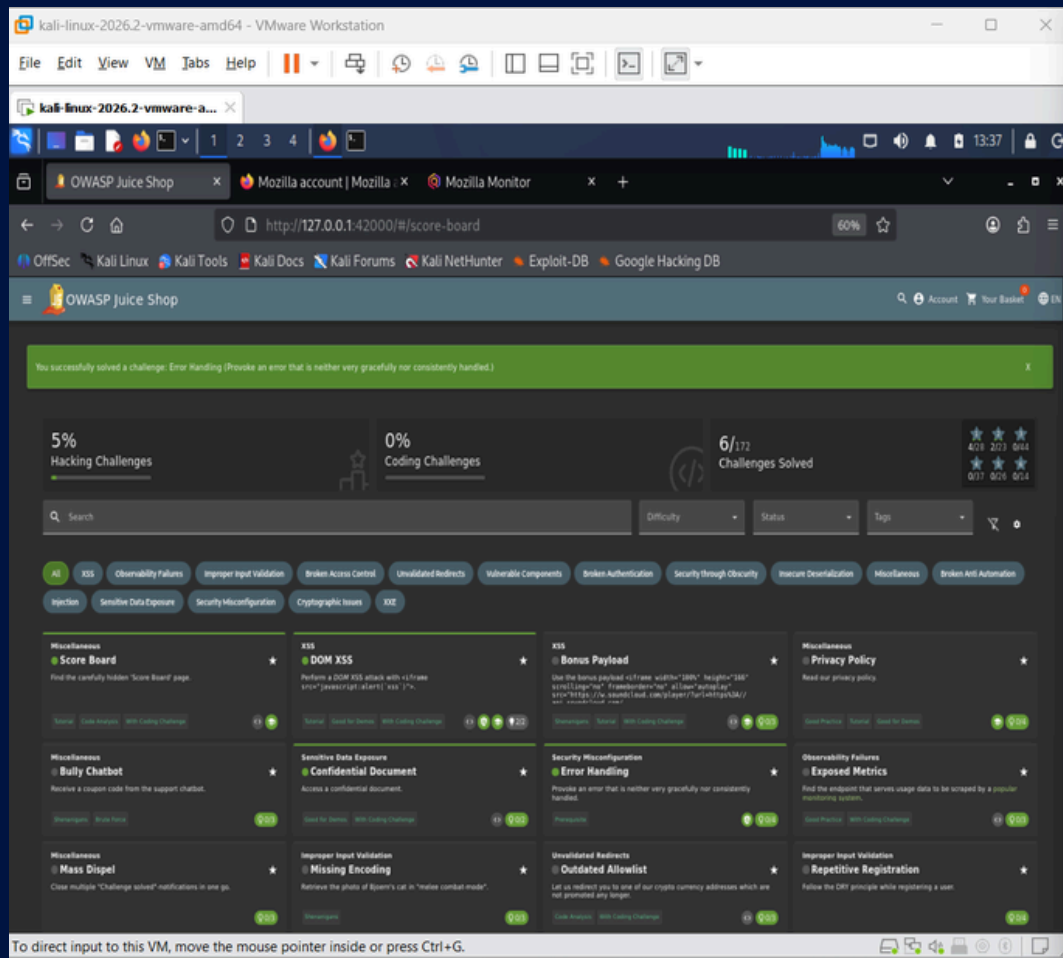


Figure 9. Juice Shop Score Board confirming the Error Handling challenge was solved.

Results Summary

No.	Challenge	Category
1	DOM XSS	Cross-Site Scripting
2	Confidential Document	Sensitive Data Exposure
3	Login Admin	SQL Injection
4	Admin Section	Broken Access Control
5	Error Handling	Security Misconfiguration

Result

No.	Finding	Severity	Verification
1	Session cookie missing HttpOnly	Low	✓ Confirmed with cURL and Burp
2	Missing HTTP security headers	Low / Informational	✓ Confirmed with cURL
3	ASP.NET version disclosure	Low / Informational	✓ Confirmed with cURL
4	ASP.NET technology disclosure	Informational	✓ Confirmed with cURL
5	HTTP TRACE	—	✗ Not confirmed; server returned 501
6	Internal IP disclosure	—	✗ Not confirmed; endpoint returned 403

- **Key observations:**

The assessment demonstrated that the application exposes certain server and framework information through HTTP response headers. The session cookie was also found to lack the HttpOnly attribute.

Burp Suite provided additional visibility into the application's login page and confirmed the presence of the username and password form parameters without requiring submission of real credentials.

Observation

During the security assessment of the locally deployed OWASP Juice Shop application, five different vulnerabilities were successfully identified and demonstrated. The testing showed that the application contained weaknesses in multiple security areas, including client-side input handling, sensitive information exposure, authentication, access control, and error handling.

- **The following observations were made::**

- 1.DOM XSS: User-controlled input could be executed as JavaScript in the browser.
- 2.Confidential Document: A confidential document could be accessed through the application.
- 3.Login Admin: SQL injection could be used to bypass the normal authentication process and access the administrator account.
- 4.Admin Section: The administration functionality could be accessed and the corresponding challenge was successfully completed.
- 5.Error Handling: The application exposed detailed HTTP error information and server-side stack-trace details.

These observations demonstrate that different layers of the application require appropriate security controls and input validation.

Conclusion

The OWASP Juice Shop security assessment was successfully completed on the authorized local training environment. Five different vulnerabilities were identified and successfully demonstrated across multiple security categories.

The assessment provided practical experience in identifying vulnerabilities, reproducing their effects, collecting evidence through screenshots, and understanding appropriate security mitigations.

- **The findings demonstrate the importance of:**

1. Secure input handling and output encoding
2. Proper protection of sensitive information
3. Secure authentication mechanisms
4. Effective authorization and access-control checks
5. Safe error handling that does not expose internal application details

Overall, the assessment objectives for the Intermediate Level — OWASP Juice Shop Security Assessment were achieved through hands-on testing and documented evidence.